

Topic 6 - Optimizing the Monitoring Setup

420-1C1-DW Preventative Monitoring - Class 17, Friday October 16, 2026
AEC Cybersecurity: Prevention and Intervention (LEA.D8)
6.1 Updating the reference databases - 6.2 Reducing the impact on performance - 6.3 Improving coverage - 6.4 Fewer false alarms - 6.5 Recommending tools and improvements
Cyber.SoHo Educational Hub - Asen Grozdanov

Before we start: rules of this module

- Educational material - fictional network (Atelier Nordik inc.), isolated lab data only
- Every tool and technique of today is applied only in your Authorized Lab Environment, on Designated Targets
- Monitoring data is treated as personal information: keep the minimum, delete when the exercise is marked
- Check every download and link before you trust it (VirusTotal, checksums)
- Legal Notice, Terms of Use and Acceptable Use Policy v2.0 - sections 6.4, 6.7, 7.2, 7.4, 14.2

Plan and timing (60 minutes)

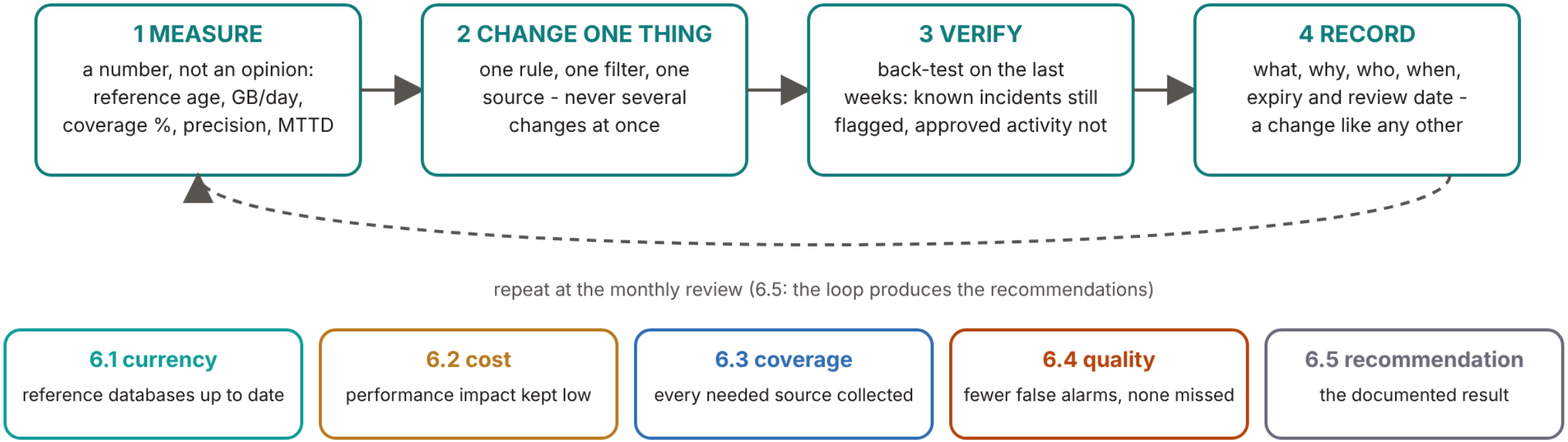
- 0:00 Opening - where we are, the optimisation loop
- 4:00 6.1 Updating the reference databases (11 min)
- 15:00 6.2 Reducing the impact on performance (10 min)
- 25:00 6.3 Improving coverage (11 min)
- 36:00 6.4 Fewer false alarms (12 min)
- 48:00 6.5 Recommending tools and improvements (9 min)
- 57:00 Lab 3 Optimise step, Quiz 4 reminder, close

Learning outcomes (competency EZ01, element 5)

- 5.1 Comprehensive update of reference databases
- 5.2 Minimise the impact of surveillance activities on network performance
- 5.3 Improved surveillance coverage
- 5.4 Improved quality and accuracy of results
- 5.5 Careful recommendation of tools to improve surveillance capabilities
- Today's deliverables: baseline v2, monitoring budget, coverage matrix, tuning record, ranked recommendations + owner memo

The optimisation loop: measure - change one thing - verify - record

Figure 6.0-1 The optimisation loop of Topic 6 - every sub-topic applies the same four steps to one property of the setup



Where we are: Atelier Nordik, October 2026

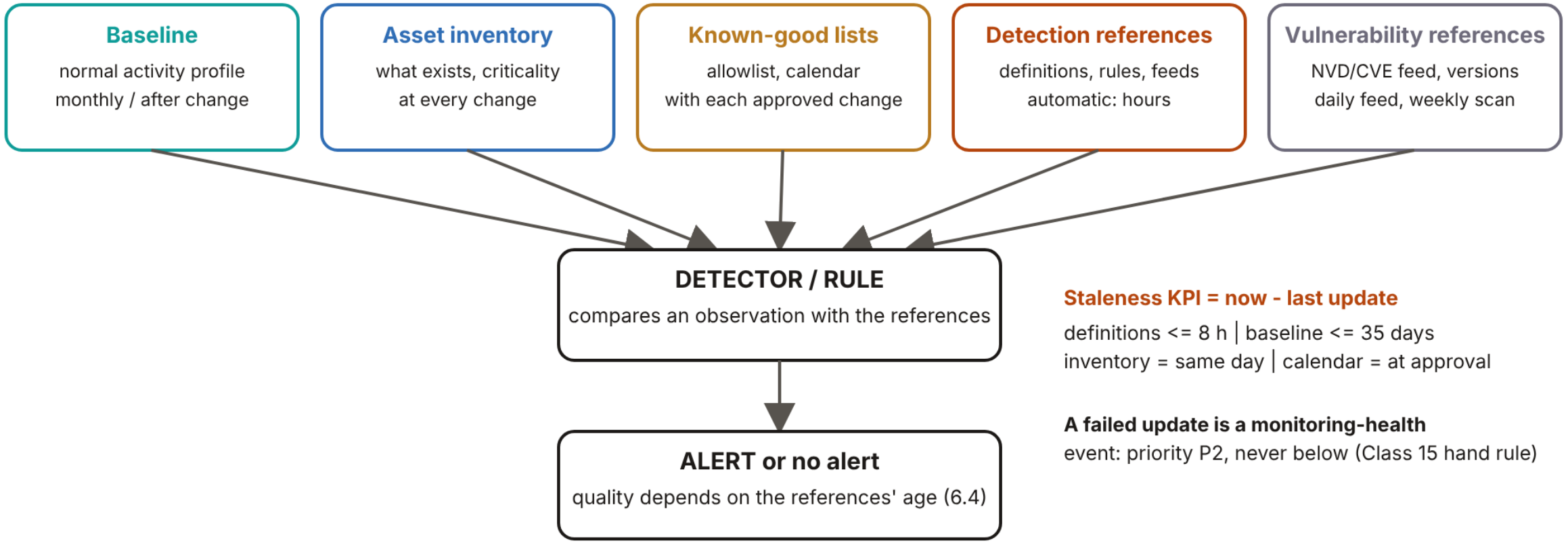
- SRV-AD01 (crit. 5), OPNsense-FW (5), srv-web01 DMZ (4), MON-250 monitoring server (4), 14 workstations (2)
- Inputs of today: baseline of WS-10-44 (Class 15), Thursday capture (Class 14), weekend alerts A-01..A-12, case A-09 (Class 16)
- Lab 3 Part 3 'Optimise' = five files, one per example
- Same scripts, your own data: the numbers differ, the method does not

6.1 Updating the reference databases

Outcome: explain what a reference database is, update a baseline without contaminating it, record the update as a change
Video: Secure Baselines (Messer, 4:11) - Video: Threat Intelligence (Messer, 4:46)
Example 6.1: refreshing the baseline of WS-10-44 (deliverable 1)

Five families of reference databases feed the detectors

Figure 6.1-1 Five families of reference databases feed the detectors - each one ages differently



Why references age

- Drift: normal activity changes (new staff, new hours, software updates)
- New threats: a definition set that is not refreshed cannot recognise a new signature (ITSAP.10.096)
- New assets: a device missing from the inventory has no criticality and no coverage
- Age metric = time since the last successful update - a KPI with a target
- Targets: definitions <= 8 h, baseline <= 35 days, inventory same day, calendar at approval

Updating a baseline without poisoning it

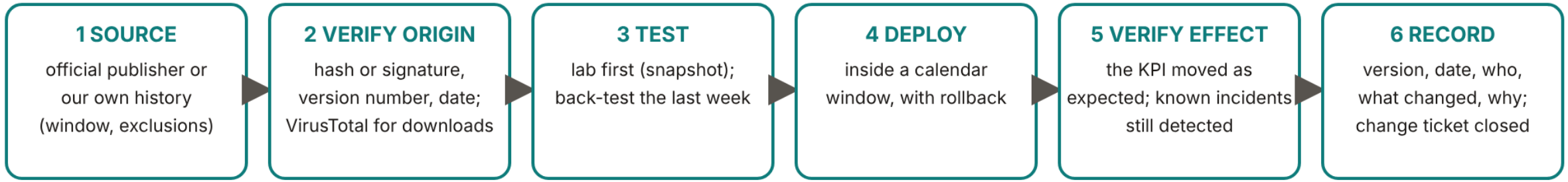
- Rolling window: the last 4-6 weeks of workdays
- Exclude confirmed incident hours - otherwise the baseline learns that the attack is normal (poisoning)
- 19:00 hour: mean 3, sd 1.5; with the scan hours included: mean about 6, sd about 12 - the next scan scores z 3.5 instead of 29
- Approved but unusual activity (Patch Wednesday) goes into its own profile, used only with >= 5 samples
- Version the file (v2 next to v1) and write a change record - never edit in place
- Pooled mean and pooled variance combine old statistics with new samples exactly

Detection references: update with verification

- External references are fetched: fetching is the step where errors occur most often
- A failed update is a monitoring-health event: never below P2
- An update is a change: ticket, calendar window, verification step (the three things missing from CH-2026-090)
- Frequency differs by family (4 h, daily, hourly, monthly, at every change); the procedure does not

The six-step update procedure

Figure 6.1-3 Updating a reference database is a change: six steps, each leaving a trace

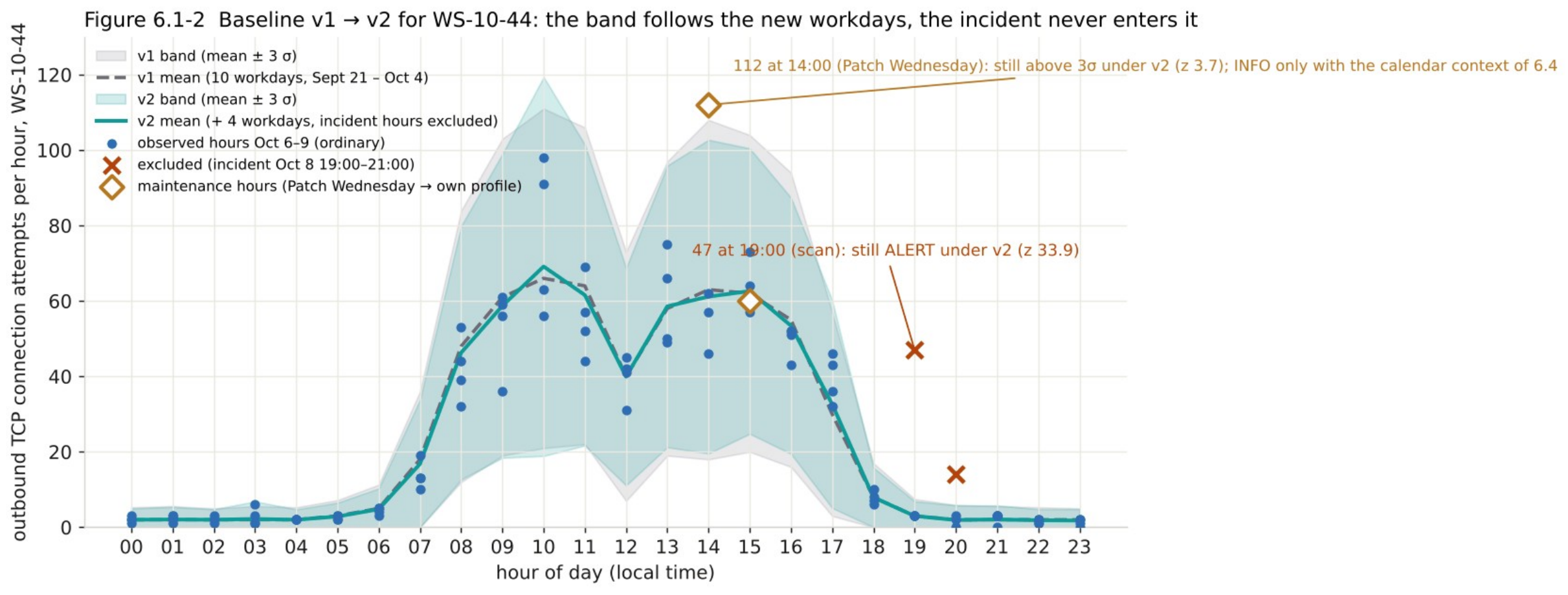


Baseline rules of this course: rolling window of workdays - incidents excluded (never teach the baseline that an attack is normal) - maintenance windows in their own profile - minimum 5 samples per hour before a profile is used - versioned files (v1, v2) and a change record - back-test before the new version replaces the old one.

Example 6.1 (1/2) - task and inputs

- Task: refresh the WS-10-44 hourly baseline with the week of Oct 6-9
- Exclude the scan hours Oct 8 19:00-21:00 (CASE-2026-015); keep Patch Wednesday in its own profile
- Inputs: baseline_hourly.csv (n = 10), observed_week.csv (96 h), exclusions.csv, maintenance_calendar.csv
- Script: update_baseline.py (Python, standard library)
- Deliverable 1 of Lab 3 Optimise: baseline_hourly_v2.csv + baseline_change_record.csv

Example 6.1 (2/2) - results



Check-in 6.1

- Flash cards: reference database - poisoning - the three stored numbers - failed update priority - six update steps
- Four MCQ + two MSQ in the module (hints and explanations included)
- Key sentence: a reference database is never edited in place; it is versioned, back-tested and recorded

6.2 Reducing the impact of monitoring on network performance

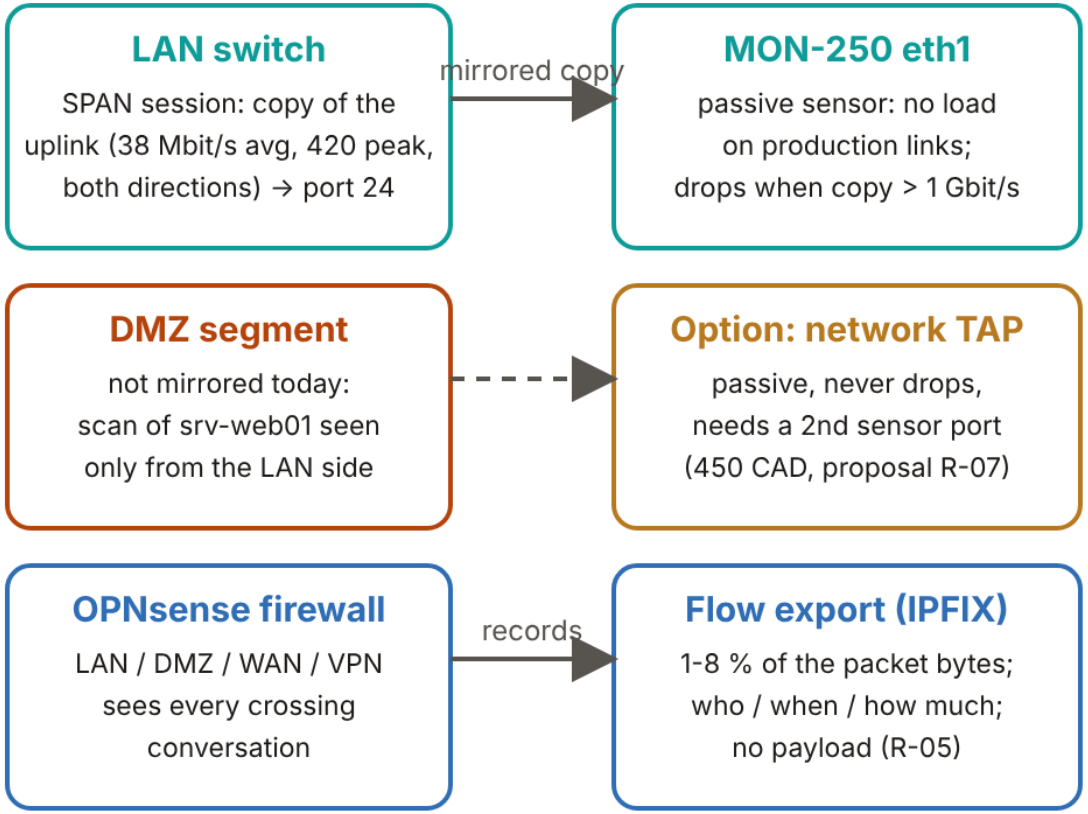
Outcome: name the four cost components, choose a strategy that keeps every needed detection, measure before and after
Video: Logs and Monitoring (Messer, 13:06) - Video: SNMP (Messer, 8:58)
Example 6.2: the monitoring budget of the LAN mirror (deliverable 2)

Monitoring has a cost: four components

- Bandwidth: mirrored copy, log forwarding, flow export, polling
- Host resources: agent CPU and memory, verbose audit policy, local capture
- Collector storage: every byte received is written, indexed and kept
- Sensor capacity: frames beyond what the sensor can process are dropped - a dropped frame never existed for the detector
- Fifth cost: every gigabyte stored is a gigabyte someone must search

Passive collection: SPAN, TAP, inline

Figure 6.2-1 Where the sensor sits decides what monitoring costs the network - Atelier Nordik, October 2026



Cost components of monitoring (measure each one)

Bandwidth
mirror copy, log forwarding, polling, flow export

Host CPU / memory
agents, verbose audit policy, local capture

Collector storage
410 GB/day full capture vs 48 GB/day filtered

Sensor capacity
packet drops when the copy exceeds the port speed

People
every GB stored is a GB someone must search

Rule: never remove data a detection rule depends on (6.3 before 6.2)

Reducing the volume - and what each technique loses

- Capture filter (BPF): drops known-good bulk conversations at the sensor - they become invisible (write it in the coverage matrix)
- Flow records (NetFlow/IPFIX): one record per 5-tuple with counters; 1-8 % of the bytes; loses the payload
- Sampling 1:N: cheapest, loses short events - at 1:10 a 16-frame scan cannot reach the 10-port rule and six SYN frames survive only about half of the time
- Sampling is for capacity planning, not for rules that count events

Reducing the load at the source

- Log level and filtering: keep every security event (4624/4625/4688, Defender 2000/2001), drop debug records - measure events per second per source
- Polling interval: SNMP counters every 5 minutes; urgent states by traps
- Scheduling: heavy jobs outside business hours and in the calendar (the Sunday scan produced four false alarms)
- Buffering and compression on forwarders; rotation and tiered retention (90 days searchable, 1 year compressed)

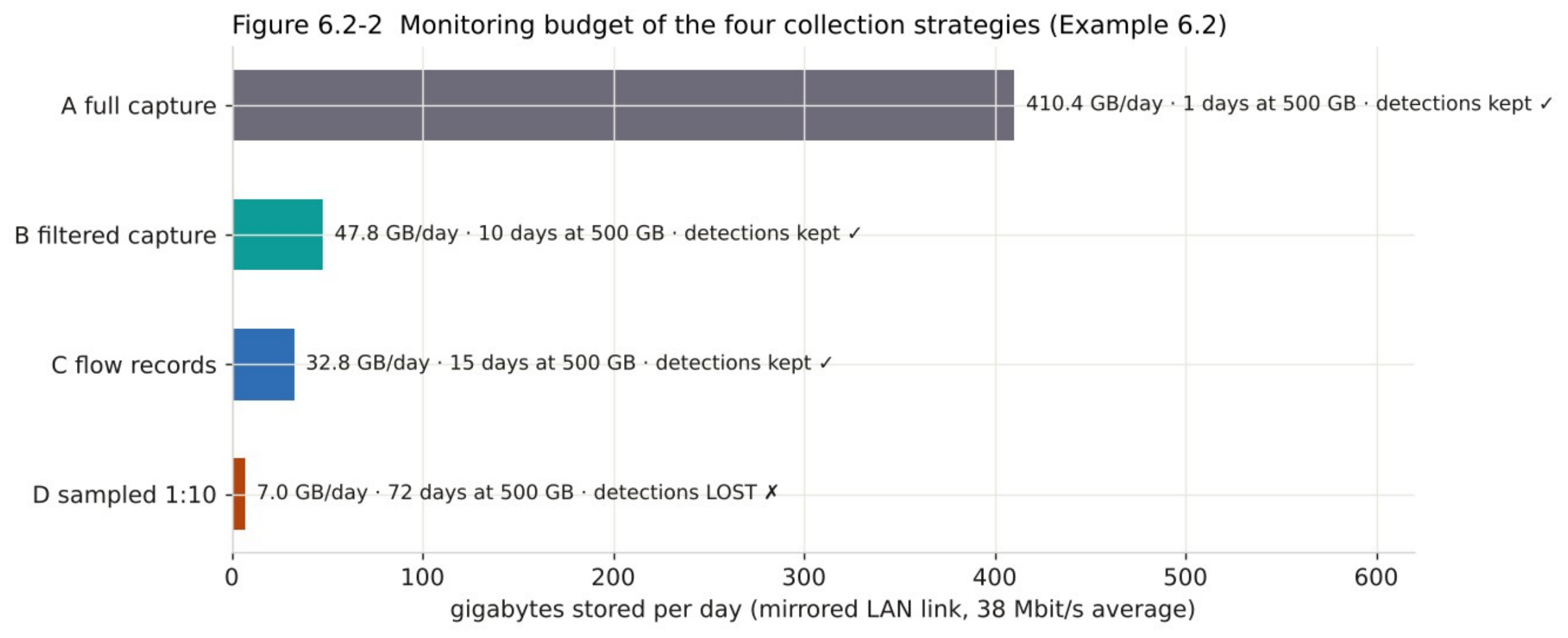
Measure before and after - and the rule above every saving

- KPIs: mirror-port utilisation %, sensor drop counter, GB/day, events per second, agent CPU %
- Never remove the data a detection rule depends on: trace each reduction to the rules it affects
- Coverage (6.3) is decided before cost (6.2): the cheapest strategy that keeps every needed detection
- Legal side: collect only what is necessary, keep it only as long as necessary (Law 25; Legal Notice 7.2)

Example 6.2 (1/2) - task and inputs

- Task: GB/day for four strategies from the 5-minute sample (68 frames) and the SNMP utilisation (38 Mbit/s avg, 420 peak)
- A full capture - B filtered capture - C flow records - D 1:10 sampling
- Two detection columns: 16-port scan (needs 10 ports), 6 unanswered SYN to port 4444 (needs 1)
- Script: estimate_capture_load.sh (bash + awk)
- Deliverable 2 of Lab 3 Optimise: monitoring_budget.csv, one strategy per segment

Example 6.2 (2/2) - the monitoring budget



Check-in 6.2

- Flash cards: four cost components - SPAN cost - what flows, filters and sampling lose - the rule above savings - daily volume arithmetic
- Four MCQ + two MSQ in the module
- Key sentence: the cheapest strategy that keeps every needed detection, not the cheapest strategy

6.3 Improving monitoring coverage

Outcome: define coverage, build the matrix, compute the weighted score, rank gaps, add source-health monitoring
Video: Network Appliances (Messer, 11:56) - Video: Hardware Tools (Messer, 8:40, from 3:40)
Example 6.3: the coverage matrix of Atelier Nordik (deliverable 3)

What coverage is

- Coverage = the share of what we need to observe that we actually observe
- Three dimensions: assets (weighted by criticality), data sources, detection needs
- Coverage matrix: assets x sources; cells collected / partial / missing / n-a
- Gap = required cell not collected; blind spot = gap that blocks a question
- Volume is not coverage: 410 GB/day on one segment, score 58.8 %

Seven ways coverage is lost

- Source not collected (OPNsense filter log stays local 7 days)
- Event type not enabled (no 4688, no Sysmon: 'which process?' unanswerable)
- Segment not observed (DMZ and VPN not mirrored)
- Silent source (srv-web01 since Sat 11:20, A-12)
- Clock drift (WS-10-31, 2.4 s, A-07)
- Retention too short; encrypted or summarised traffic
- Joint guidance (Cyber Centre, 2024): logging policy, central collection, integrity, detection strategy

Needs, ATT&CK techniques and the sources that answer them

Figure 6.3-3 Detection needs, the ATT&CK techniques behind them, and the source that answers each one

need	question (short)	ATT&CK technique / tactic	source(s) missing
N1	VPN account behind 10.8.0.9?	T1133 External Remote Services	OPNsense-FW:vpn_log
N2	logon success on srv-web01 after guessing?	T1110 Brute Force	srv-web01:source_health
N3	which process on WS-10-44?	T1046 Network Service Discovery	WS-10-44:process_log
N4	firewall blocked the SYNs to :4444?	T1571 Non-Standard Port	OPNsense-FW:firewall_log
N5	silent source detected in 30 min?	TA0112 Defense Impairment (tactic)	srv-web01:source_health + MON-250:source_health
N6	failed definition updates in 8 h?	T1685 Disable or Modify Tools	(none: answerable)
N7	DMZ side of the scan?	T1046 Network Service Discovery	MON-250:packet_mirror_DMZ + OPNsense-FW:flow_export
N8	one time line (drift)?	(no technique: data quality)	WS-10-31:ntp_sync

Technique numbers follow MITRE ATT&CK v19 (T1685 Disable or Modify Tools replaced T1562.001 in April 2026).

The coverage method and the score

Figure 6.3-2 The coverage method: from needs to closed gaps (Example 6.3, Lab 3 Optimise)



Coverage score = sum(criticality x collected cells) / sum(criticality x required cells) - a partial source counts one half. October: 70 / 119 = 58.8 %.

Blind spots found in Lab 3: VPN account mapping, firewall decisions, process names on workstations, the DMZ side of the scan, silent sources, one clock.

Monitoring the monitoring: source health

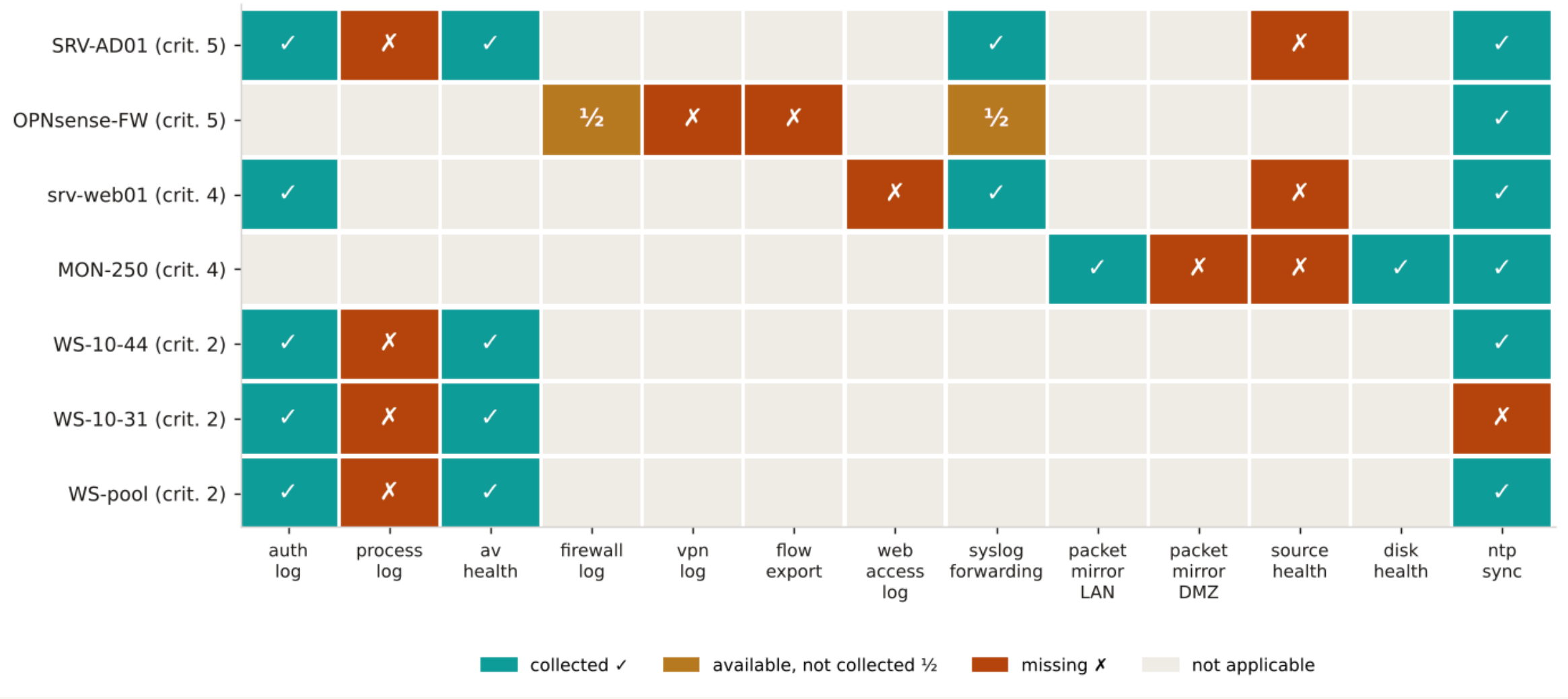
- Heartbeat rule: a source that normally produces events has produced none for 30 min → P2
- Silence is indistinguishable from an attacker who disabled logging
- Needs two references: expected rate per source, maintenance calendar (a planned reboot is not silence)
- Would have found A-12 at 11:50 on Saturday instead of during Sunday triage
- Largest single coverage improvement, effort 1

Example 6.3 (1/2) - task and inputs

- Task: matrix 7 assets x 13 sources, weighted score, needs evaluation, ranked gaps with closure actions
- Inputs: assets.csv, required_sources.csv, sources.csv (33 pairs with status), needs.csv (8 questions)
- Script: coverage_matrix.py (Python)
- Deliverable 3 of Lab 3 Optimise: coverage_matrix.csv + coverage_gaps_ranked.csv

Example 6.3 (2/2) - the coverage matrix

Figure 6.3-1 Coverage matrix of Atelier Nordik (weighted score 58.8 %, 14 gaps, 7 of 8 needs blocked)



Check-in 6.3

- Flash cards: coverage definition - gap vs blind spot - score formula - seven losses - source-health rule
- Four MCQ + two MSQ in the module
- Key sentence: unknown is not collected; silence is a P2

6.4 Improving the quality and accuracy of results

Outcome: measure precision and recall, explain false alarms, apply the seven tuning methods with a back-test, document each change
Video: Security Monitoring (Messer, 10:27, from 7:30) - Video: Analyzing Vulnerabilities (Messer, 10:29)
Example 6.4: replaying four weeks of alerts through rule set v2 (deliverable 4)

Four outcomes, two ratios

Figure 6.4-2 The four outcomes of a rule and the two quality numbers built from them



precision = TP / (TP + FP)
share of alerts that were correct

recall = TP / (TP + FN)
share of real events detected

benign true positive = correct alert about
approved activity: closed with a reason code, never by suppressing the rule

Tuning raises precision (fewer FP) without lowering recall (no new FN): every change is back-tested on the last 4 weeks before it is deployed.

Why false alarms occur

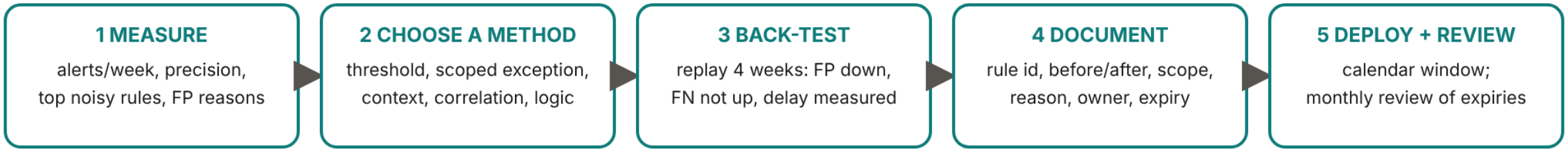
- Stale reference: one service account with a wrong password = 28 of 42 false alarms (fix the password, not the rule)
- Rule without context: the baseline rule fired on Patch Wednesday
- Measure that does not represent the failure: age of last update fired on switched-off laptops and waited 36 h on A-09
- Approved activity that looks like an attack: the authorised scan, the vendor session
- Threshold on the wrong time scale: 10/10 min caught two fast attacks and missed a slow one (8 per 10 min for an hour)

Seven tuning methods (in order of preference)

- 1 Threshold adjustment - add a slower second condition (10/10 min OR 30/60 min)
- 2 Scoped exception for one known approved source
- 3 Context enrichment: calendar, allowlist, criticality
- 4 Correlation: two independent signals
- 5 Aggregation: one alert per source per window, count inside
- 6 Rule logic change: measure the failure itself (consecutive failed attempts)
- 7 Closure with reason code - no change to the rule (benign true positives)
- Every method is verified by a replay of the last four weeks

The tuning loop and the shape of a scoped exception

Figure 6.4-3 The tuning loop and the shape of a scoped exception



A scoped exception names ALL of: asset + account (or source) + time window + activity + owner + reason + expiry date

nas-sync @ SRV-AD01, 01:00-01:10, logon type 4, owner ops, reason 'stale password (CH-2026-094)', expires 2026-11-15

never: 'ignore nas-sync' - never: 'ignore SRV-AD01 at night' - an exception without expiry is a permanent blind spot

Detection delay against false alarms: the A-09 rule (R4)

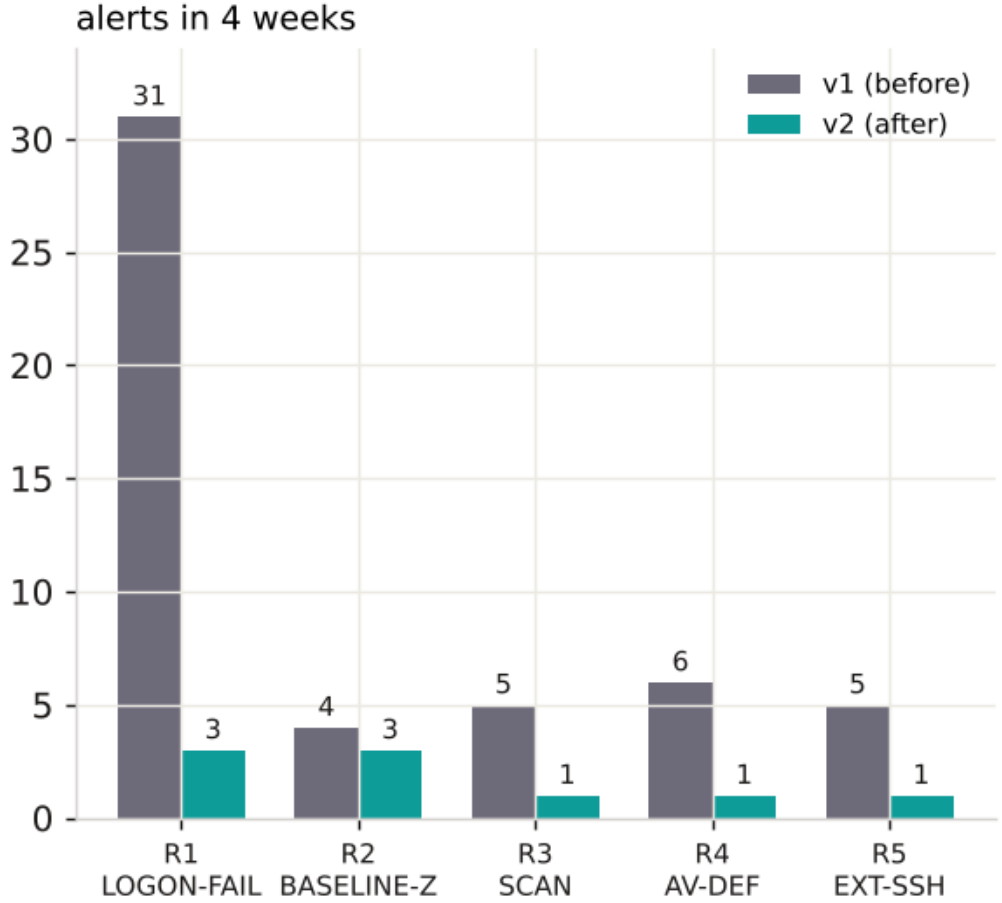
- v1: age of last successful update > 24 h, checked once a day at 09:30 - alert after 36 h 15 min; 5 false alarms on switched-off laptops
- v2: two consecutive failed attempts (Defender event 2001), evaluated at every event - alert 4 h after the first failure (8 h after the last success at worst)
- A silent host is a coverage question (6.3), not a failure
- MTTD 36.25 h to 4 h, false alarms 5 to 0, recall unchanged - proven by the replay

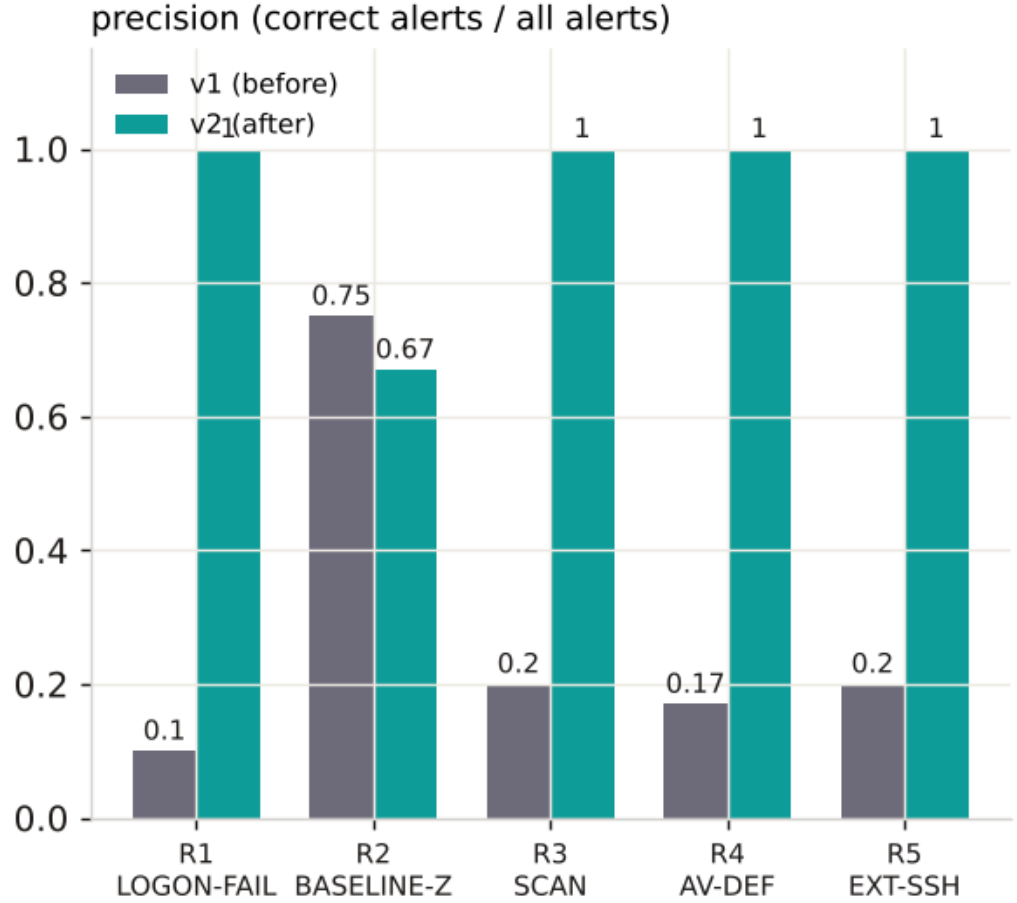
Example 6.4 (1/2) - task and inputs

- Task: replay 51 alerts (labelled at closure) and 7 ground-truth events through rule set v2
- v2 = slow-attack condition + three scoped exceptions (one exception, two allowlist entries) + calendar context + consecutive-failure logic
- Outputs per rule and version: alerts/week, true, benign, false, missed, precision, recall, delay
- Script: tune_rules.py (Python); rule sets as JSON
- Deliverable 4 of Lab 3 Optimise: tuning_metrics.csv + tuning_changes.csv

Example 6.4 (2/2) - before and after

Figure 6.4-1 Tuning replay over 4 weeks: 51 → 9 alerts, precision 0.18 → 0.89, one missed slow attack now detected (Example 6.4)





Check-in 6.4

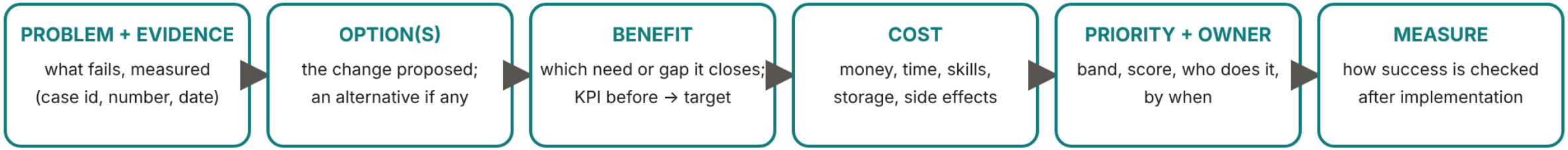
- Flash cards: precision and recall - benign true positive - scoped exception - R4 v1 vs v2 - replay
- Four MCQ + two MSQ in the module
- Key sentence: fewer false alarms and no new misses, proven by a replay, written in the record

6.5 Recommending tools and improvements

Outcome: write a recommendation an owner can decide on; select tools with the Topic 3.2 criteria and the legal checks; prioritise with benefit x (6 - effort)
Video: Security Tools (Messer, 14:06) - Video: Third-party Risk Assessment (Messer, 11:36)
Example 6.5: ranking the twelve improvements and writing the owner memo (deliverable 5)

A recommendation is a decision document

Figure 6.5-2 Anatomy of a recommendation - a proposal the owner can decide on



Two readers, two documents (Topic 5.5): owner memo = plain words, dollars, one decision, one page, TLP:AMBER | technical annex = ids, hosts, evidence, side effects.

Tool choice follows the criteria of Topic 3.2 (need, fit, total cost, footprint, skills, licence/legal, security of the download, reversibility) - table T6-5-1.

Selecting a tool: Topic 3.2 criteria and the legal checks

- Need - fit - total cost of ownership - performance footprint (6.2) - skills and support
- Licence and legal: data location, personal information (Law 25), export restrictions
- Security of the tool itself: authentic download (hash, signature), VirusTotal (Legal Notice Annex C)
- Reversibility: clean removal after a failed trial
- Shortlist for a 14-person firm: Sysmon, OPNsense flow export + nfdump, Suricata, Wazuh (after training)
- Every trial in the Authorized Lab Environment first (Legal Notice 6.4, 7.4)

Prioritising: benefit, effort, bands

Figure 6.5-1 Benefit–effort matrix of the 12 recommendations (number = R-id; colour = band; priority = benefit × (6 − effort))



Two readers, and measuring afterwards

- Owner memo: one page, plain words, no host names or tickets, quick wins first, cost in dollars, one decision with a reply date, KPIs; TLP:AMBER+STRICT top and bottom (annex: TLP:AMBER)
- Technical annex: the ranked table with identifiers, evidence, side effects, owners
- After approval the loop restarts: monthly KPIs (alerts/week, precision, coverage score, MTTD, reference age, implemented on time)
- Targets of the memo: alerts/week < 4, precision > 80 %, coverage > 85 %, MTTD < 8 h

Example 6.5 (1/2) - task and inputs

- Task: score 12 candidates (benefit, effort, cost), rank, assign bands, totals, owner memo + technical annex
- Input: recommendations_input.csv (evidence, benefit 1-5, effort 1-5, costs, side effects, owner wording)
- Script: New-RecommendationMemo.ps1 (PowerShell 7 / 5.1)
- Deliverable 5 of Lab 3: recommendations_ranked.csv + owner memo + technical annex

Example 6.5 (2/2) - the ranked list

- 1 R-01 verification step + calendar entry (25, quick win, 0 CAD)
- 2 R-02 two consecutive failed updates (20, quick win) - 3 R-06 source-health rule (20, quick win)
- 4 R-03 forward firewall + VPN logs (20) - 5 R-05 flow export (16) - 6 R-11 monthly tuning review (16)
- Planned: R-08 time sync (15), R-04 Sysmon (15), R-09 storage (12), R-12 password rotation (10), R-07 DMZ tap (9)
- Later: R-10 Wazuh (4) - Totals: 630 CAD one-time, 0 CAD/year, six quick wins
- Decision requested: approve quick wins for next week, planned items for the November window; reply by October 23

Check-in 6.5

- Flash cards: six parts - score and bands - eight criteria - memo vs annex - four categories
- Four MCQ + two MSQ in the module
- Key sentence: a recommendation without evidence, KPI and measure is an opinion

Lab 3 Optimise step - due tonight - and what comes next

- Deliverable 1: baseline_hourly_v2.csv + baseline_change_record.csv (Example 6.1)
- Deliverable 2: monitoring_budget.csv, one strategy per segment (Example 6.2)
- Deliverable 3: coverage_matrix.csv + coverage_gaps_ranked.csv (Example 6.3)
- Deliverable 4: tuning_metrics.csv + tuning_changes.csv (Example 6.4)
- Deliverable 5: recommendations_ranked.csv + owner memo + technical annex (Example 6.5)
- Quiz 4 (5 %) covers all of Topic 5 - published separately. Class 18 Sat Oct 17: final exam review. Class 19 Mon Oct 19: final exam (40 %), Topics 1-6

Links (1/2) - standards and guidance

- Cyber.SoHo Legal Notice, Terms of Use and Acceptable Use Policy v2.0
- NIST SP 800-137 (continuous monitoring) - NIST SP 800-92 Rev. 1 draft (log management planning) - NIST SP 800-94 (IDPS)
- NIST Cybersecurity Framework 2.0 (DE.CM, DE.AE)
- Cyber Centre: Best practices for event logging and threat detection (2024); Top 10 IT security actions (ITSM.10.089); How updates secure your device (ITSAP.10.096)
- MITRE ATT&CK (v19) and ATT&CK Navigator - CIS Controls - FIRST TLP 2.0
- Québec Act P-39.1 (Law 25) - Commission d'accès à l'information

Links (2/2) - tools and videos

- Sysmon (Microsoft Sysinternals) - OPNsense - nfdump - Suricata - Zeek - Wazuh - Wireshark - tcpdump - VirusTotal
- Professor Messer SY0-701 and N10-009 course indexes (source of the ten videos, all under 15 minutes)
- Every download: official source, checksum, VirusTotal (Legal Notice 14.2, Annex C)



Thank you - see you tomorrow for the final exam review

Cyber.SoHo Educational Hub - From the Industry to the Classroom

Educational material - Legal Notice, Terms of Use and Acceptable Use Policy v2.0 applies
© 2026 Cyber.SoHo - all rights reserved